

PROJECT SYNOPSIS

"AGILEGRAPH"

Graph-Learned Crypto-Agility Risk Scoring for Post-Quantum Migration

Heterogeneous GNN Risk Propagation and Explainable Migration Prioritization

Students

1. Spoorthi — NNM23CB058
2. Sindhoora R — NNM23CB057
3. Nivedita V Shetty — NNM23CB033
4. Sujan S — NNM23CB062

Guide Name: Ms Madhushree

Department: Department of Computer Science (Cyber Security)

Institution: NMAM Institute of Technology (NMAMIT), Nitte (Deemed to be University),
Karnataka

Academic Year: 2023 – 27 (Final Year, B.Tech)

1. Introduction

The security of nearly every digital system in use today — banking transactions, healthcare records, government communications, and everyday web traffic — rests on public-key cryptographic algorithms such as RSA and ECC. Large-scale, fault-tolerant quantum computers are expected to be capable of breaking these algorithms using Shor's algorithm, and while such machines do not yet exist at the required scale, the risk is not purely theoretical. Adversaries can already record encrypted traffic today and decrypt it once sufficiently powerful quantum computers become available, a strategy widely referred to as "harvest-now, decrypt-later." In response, the U.S. National Institute of Standards and Technology (NIST) finalized its first set of post-quantum cryptography (PQC) standards in August 2024 — ML-KEM (FIPS 203), ML-DSA (FIPS 204), and SLH-DSA (FIPS 205) — giving organizations quantum-resistant algorithms to migrate to [1], [2], [3].

However, having quantum-safe algorithms available does not solve the migration problem by itself. Most organizations do not have a reliable inventory of where cryptography is actually used across their code, certificates, libraries, and network endpoints, which makes planning a migration extremely difficult [4], [5]. This project, AgileGraph, addresses that gap by combining automated cryptographic discovery with a graph-based AI model that scores and ranks cryptographic risk across an organization, producing a clear, explainable, and prioritized migration roadmap.

2. Problem Statement

Organizations urgently need to migrate to post-quantum cryptography, but most do not know where their vulnerable cryptography is located in the first place — it is scattered across old libraries, forgotten certificates, and code that has not been touched in years. Discovering this cryptography today is a largely manual process: security teams search codebases, check certificates, and inspect network traffic by hand, which is slow, error-prone, and does not scale. Even when weak cryptography is found, existing tools present it as a flat, unprioritized list — telling a team that "this certificate is outdated" but not that "fixing this certificate first will protect the most sensitive data with the least effort." There is currently no open, explainable system that models how cryptographic weaknesses propagate across an interconnected system of code,

certificates, libraries, and sensitive data, and uses that model to produce a defensible, risk-ranked migration order.

3. Objectives

- **To design and implement an automated cryptographic discovery and risk assessment framework** that scans source code, live network endpoints/certificates, and dependency manifests across Java, Python, and Go projects; constructs a heterogeneous cryptographic risk graph comprising six categories of entities and seven relationship types; and generates an open, reproducible heuristic risk score using measurable and auditable factors including data sensitivity, asset criticality, internet exposure, cryptographic algorithm strength, known vulnerabilities (CVEs), dependency centrality, and migration effort.
- **To develop a Graph Attention Network (GATv2)** that uses the heuristic risk score as node initialization and a weak supervisory signal to refine post-quantum migration priorities by propagating contextual risk across shared libraries, certificates, and dependency relationships that cannot be captured through standalone heuristic analysis.
- **To evaluate the proposed framework** by benchmarking the GNN-refined prioritization against the heuristic baseline and simpler rule-based ranking approaches, quantifying the impact of graph-based contextual propagation, and validating the results using an independently collected, held-out expert-annotated dataset with categorical (High / Medium / Low) risk labels.
- **To develop an explainable web-based decision support system** that presents prioritized migration recommendations, plain-language explanations, estimated risk reduction for each asset, and a separate Mosca Readiness Index—an organization-configurable planning indicator based on data confidentiality lifetime, migration duration, and an adjustable assumed quantum-capability horizon—kept outside the GNN training loop to ensure that the core methodology remains independent of speculative quantum timeline assumptions.

4. Literature Survey

4.1 Existing System

Cryptographic discovery today is largely handled through manual audits or commercial scanning/inventory tools such as Keyfactor and AppViewX, which catalogue certificates and keys but stop short of modelling how a weakness in one component affects the rest of the system. The emerging Cryptography Bill of Materials (CBOM) concept, standardized as part of CycloneDX 1.6 in 2024 (published as ECMA-424), formalizes cryptographic inventory in a machine-readable format and is supported by open tools such as CBOMkit [9]. NIST's own National Cybersecurity Center of Excellence (NCCoE) migration guidance similarly emphasizes cryptographic discovery and crypto-agility as first steps in PQC migration planning [4].

4.2 Limitations of Existing System

- Discovery tools identify cryptographic assets but produce flat, unprioritized lists with no understanding of downstream impact.
- Risk-scoring formulas in commercial tools are closed and vendor-specific, making them difficult to audit or trust.
- No existing tool models cross-system dependency — i.e., what breaks elsewhere if a given certificate, library, or key is not migrated.
- Explanations for why an item is flagged as risky are rarely provided, resulting in a "black box" experience for security teams.
- Migration-order simulation (comparing outcomes of different fix sequences) is largely absent from current tooling.
- Where risk formulas do exist, they are typically presented as ground truth rather than as an auditable heuristic, leaving no principled role for a learned model to add value beyond the formula itself.

4.3 Related Research Papers

Hasan et al. propose a framework for migrating to post-quantum cryptography that performs security-dependency analysis and presents real-world case studies, motivating the need for dependency-aware migration planning [4]. Alnahawi et al. survey the current state of crypto-

agility, characterizing how prepared organizations are to swap cryptographic primitives without large-scale rewrites [5]. Näther et al. conduct a systematic literature review of software migration approaches toward post-quantum cryptography, cataloguing existing tools and identifying open gaps in automated migration tooling [6]. On the AI side, Brody, Alon, and Yahav introduce GATv2, a dynamic graph-attention variant that is strictly more expressive than the original Graph Attention Network and forms the core learning architecture proposed in this project [7]. Motie and Raahemi systematically review the use of graph neural networks for financial fraud detection, illustrating how GNN-based risk propagation across heterogeneous graphs has proven effective in adjacent risk-scoring domains such as fraud and credit risk, including settings where model supervision comes from noisy or proxy labels rather than exact ground truth [8]. The OWASP CycloneDX project formalizes the Cryptography Bill of Materials as a machine-readable standard for cryptographic asset inventory, which this project extends with graph-based risk propagation rather than flat inventory alone [9]. Most directly related, recent work on quantum-safe code auditing combines static analysis with quantum-aware risk scoring for PQC migration, confirming both the novelty and the timeliness of combining automated discovery with learned risk ranking [10].

5. Proposed System

AgileGraph is structured as four cooperating layers. The scanning and data-collection layer statically analyses source code to detect cryptographic primitives (RSA, ECDSA, AES, and others) across Java, Python, and Go projects, actively scans live servers for certificate and TLS configuration weaknesses, and parses dependency manifests to flag outdated or unsupported cryptographic libraries. The results are stored in a graph database so that relationships between all discovered assets can be queried and reasoned about.

The risk-graph construction layer maps six categories of nodes — code files, cryptographic usage sites, certificates, network endpoints, libraries, and sensitive data — connected by seven relationship types (for example, "this code uses this certificate" or "this certificate protects this data"). Each node receives a starting heuristic risk score from a published, checkable formula that combines measurable factors: data sensitivity, asset criticality, internet exposure, cryptographic algorithm strength, known CVEs, dependency centrality, and migration effort. This heuristic is

deliberately kept free of any assumption about when large-scale quantum computers will arrive, so that it remains auditable and reproducible.

5.1 Weak Supervision and the Role of the GNN

A central design decision in AgileGraph is that the heuristic risk score is treated as an initial, weak-supervision estimate rather than as ground truth. If the heuristic score were used directly as the GNN's training label while also appearing as a node feature, the model would be able to reproduce the label without learning anything from the graph — a form of data leakage that would undermine the model's contribution. To avoid this, the heuristic score is used only as node initialization and as a noisy training signal, and the GATv2 model is trained to refine this estimate by propagating contextual information across the graph: shared libraries used by many services, certificates protecting multiple sensitive data stores, and dependency hubs whose migration reduces risk across several connected assets simultaneously. This is a recognized pattern in graph and weakly-supervised learning, comparable to distant supervision and pseudo-labeling approaches used elsewhere in machine learning [8].

The GNN's contribution is evaluated, not assumed. After training, the project compares the heuristic-only ranking against the GNN-refined ranking to quantify how much graph propagation actually changes prioritization, and reports specific case studies where the GNN reorders assets relative to the heuristic because of relational structure the heuristic cannot see in isolation (for example, a library shared across many services being promoted in priority beyond what its standalone severity would suggest).

5.2 Expert Validation

A held-out sample of roughly 50–100 assets is independently annotated by domain experts using a categorical scale (High / Medium / Low risk), collected without reference to the heuristic formula's internal weights. These annotations are used solely to evaluate whether the GNN-refined ranking agrees better with expert judgment than the flat heuristic baseline, using agreement metrics appropriate to categorical labels (weighted Cohen's kappa and macro F1). The expert-labeled sample is never used to construct or tune the heuristic formula, preserving a clean separation between the weak training signal and the evaluation ground truth.

5.3 Mosca Readiness Index

Because the projected timeline for large-scale quantum computers cannot be scientifically established, it is kept out of the operational risk score entirely. Instead, AgileGraph separately reports a Mosca Readiness Index, based on Mosca's inequality ($x + y > z$, where x is the required data confidentiality lifetime, y is estimated migration duration, and z is an assumed quantum-capability horizon). This index is presented as an organization-configurable strategic planning indicator on the dashboard, with z exposed as an adjustable parameter rather than a fixed constant, so that the model's core methodology does not depend on an unprovable assumption.

5.4 Weight Justification

The weights used in the heuristic formula are drawn from an initial literature-informed starting point and then stress-tested with a sensitivity analysis: each weight is perturbed by approximately $\pm 10\text{--}20\%$ and the resulting migration ranking is checked for stability. This provides a practical, defensible justification for the chosen weights within the scope of a B.Tech project timeline, without requiring a full Analytic Hierarchy Process (AHP) expert-elicitation study.

5.5 Presentation Layer

The presentation layer is a FastAPI backend and a React-based web dashboard where a user scans a project and receives a ranked migration to-do list, each item annotated with a plain-English explanation and an estimate of how much overall risk is reduced by addressing it, alongside the separate Mosca Readiness Index view.

6. System Requirements

6.1 Hardware Requirements

- Development workstation/laptop with a minimum of 16 GB RAM and a multi-core processor.
- GPU (NVIDIA, CUDA-compatible) recommended for accelerated GNN training, though not strictly required for the target dataset scale.
- Stable internet connectivity for certificate/TLS scanning of live endpoints.

6.2 Software Requirements

- Operating System: Linux / Windows with WSL2 / macOS

- Programming Languages: Python 3.10+, JavaScript/TypeScript
- AI/ML Libraries: PyTorch, PyTorch Geometric (GATv2Conv)
- Code Scanning: Semgrep and custom analysis scripts
- Certificate/Network Scanning: tlsx, testssl.sh, sslyze, Certificate Transparency (CT) logs
- Graph Storage: Neo4j or NetworkX
- Backend Framework: FastAPI
- Frontend Framework: React with Tailwind CSS
- Evaluation Tools: scikit-learn (weighted Cohen's kappa, macro F1), SciPy, matplotlib
- Version Control: Git / GitHub

7. Expected Outcomes

- A working end-to-end prototype that scans a codebase and live infrastructure and produces a ranked, explainable PQC migration list.
- An open, documented heuristic risk-scoring formula and a heterogeneous risk graph populated from 3–5 real open-source projects.
- A trained GATv2-based risk-propagation model, explicitly framed as refining a weak-supervision heuristic, with a quantified comparison of heuristic-only versus GNN-refined rankings.
- An expert-reviewed validation of a held-out sample of ~50–100 items using categorical (High/Medium/Low) annotations, reported with weighted Cohen's kappa and macro F1 agreement metrics.
- A separate Mosca Readiness Index module, kept outside the GNN training loop, for organization-level strategic planning.
- A functional web dashboard demonstrating the complete workflow from scan to prioritized migration output.
- A draft research paper suitable for submission to a Q1 journal or security conference, documenting the graph model, the weak-supervision risk formula, and the evaluation results.

8. Applications

- Enterprise post-quantum cryptography migration planning across banking, healthcare, telecom, and government sectors.
- Security operations center (SOC) and governance-risk-compliance (GRC) tooling for continuous cryptographic risk monitoring.
- Cybersecurity consulting engagements that require a defensible, explainable migration roadmap for clients.
- Academic and research use as an open, checkable alternative to closed vendor risk-scoring formulas.
- Supply-chain security, complementing existing Software Bill of Materials (SBOM) practices with a Cryptography Bill of Materials (CBOM)-aligned view [9].

9. Future Scope

- Extending code-scanning coverage to additional languages (C/C++, Rust, JavaScript) and cloud-native/IaC configurations.
- Integrating continuous, real-time monitoring with SIEM/SOAR platforms rather than point-in-time scans.
- Incorporating newly standardized PQC algorithms (such as HQC) and updated NIST guidance as they are released.
- Simulating and comparing multiple migration-order strategies at organizational scale, including budget and staffing constraints.
- Extending expert validation from categorical to ordinal ranking annotations if a larger expert panel becomes available, enabling rank-correlation metrics (Spearman, NDCG) alongside the categorical agreement metrics.
- Piloting the system with an industry partner to validate the risk-scoring formula against real production incident data.

10. Project Timeline

Month	Phase	Deliverable
Month 1	Planning + Design	Graph layout finalized; heuristic risk-scoring formula and weak-supervision methodology agreed with advisor; annotation protocol (categorical) defined
Month 2	Building the Scanners	Code, certificate, and dependency scanners built; graph populated from 3–5 real projects; heuristic scores computed
Month 3	Training the AI Model	GATv2 model trained using heuristic as weak supervision/initialization; baseline (heuristic-only) comparison built alongside it
Month 4	Testing + Validation	Expert-reviewed categorical (High/Medium/Low) sample collected independently; GNN-refined ranking compared against heuristic baseline using kappa/F1
Month 5	Dashboard	Web dashboard built showing the ranked migration list with explanations and a separate Mosca Readiness Index view
Month 6	Writeup	Final results, case studies of GNN reorderings, and report/paper draft completed

11. References

[1] NIST, "Module-Lattice-Based Key-Encapsulation Mechanism Standard," Federal Information Processing Standards Publication FIPS 203, National Institute of Standards and Technology, Gaithersburg, MD, USA, Aug. 2024.

[2] NIST, "Module-Lattice-Based Digital Signature Standard," Federal Information Processing Standards Publication FIPS 204, National Institute of Standards and Technology, Gaithersburg, MD, USA, Aug. 2024.

[3] NIST, "Stateless Hash-Based Digital Signature Standard," Federal Information Processing Standards Publication FIPS 205, National Institute of Standards and Technology, Gaithersburg, MD, USA, Aug. 2024.

- [4] K. F. Hasan, L. Simpson, M. A. R. Baee, C. Islam, Z. Rahman, W. Armstrong, P. Gauravaram, and M. McKague, "A framework for migrating to post-quantum cryptography: Security dependency analysis and case studies," *IEEE Access*, vol. 12, pp. 23427–23450, 2024, doi: 10.1109/ACCESS.2024.3360412.
- [5] N. Alnahawi, N. Schmitt, A. Wiesmaier, and A. Heinemann, "On the state of crypto-agility," *Cryptology ePrint Archive*, 2023.
- [6] C. Näther, D. Herzinger, S.-L. Gazdag, J.-P. Steghöfer, S. Daum, and D. Loebenberger, "Migrating software systems towards post-quantum cryptography — a systematic literature review," *arXiv preprint arXiv:2404.12854*, 2024.
- [7] S. Brody, U. Alon, and E. Yahav, "How attentive are graph attention networks?," in *Proc. Int. Conf. Learning Representations (ICLR)*, 2022.
- [8] S. Motie and B. Raahemi, "Financial fraud detection using graph neural networks: A systematic review," *Applied Soft Computing*, vol. 149, p. 110984, 2023.
- [9] OWASP Foundation, "Authoritative Guide to Cryptography Bill of Materials (CBOM)," *CycloneDX Project*, 2024.
- [10] "Quantum-Safe Code Auditing: LLM-Assisted Static Analysis and Quantum-Aware Risk Scoring for Post-Quantum Cryptography Migration," *arXiv preprint arXiv:2604.00560*, 2026.